

PHISHING EMAIL INCIDENT RESPONSE PLAYBOOK

Security Operations Center — Standard Operating Procedure

Version	1.0
Applies To	All reported or detected phishing emails — link-based, attachment-based, and BEC
Related Documents	Incident Report Template, IOC Tracker, Escalation Contact List

1. Purpose & Scope

This playbook defines the standard, repeatable process for triaging, analyzing, containing, and reporting suspected phishing emails. It applies to emails reported by end users, flagged by the email security gateway, or surfaced through SIEM correlation. It covers credential-harvesting links, malicious attachments, and business email compromise (BEC) variants.

2. Roles & Responsibilities

Role	Responsibility
Tier 1 Analyst	Initial triage, header/URL/attachment analysis, IOC extraction
Tier 2 Analyst	Sandbox detonation, deeper redirect-chain and infrastructure analysis, MITRE mapping
IR Lead	Severity classification, containment authorization, stakeholder communication
IT/Helpdesk	Credential resets, mailbox purges, endpoint isolation on IR Lead's direction

3. Severity Classification Matrix

Classify immediately after triage (Phase 1). Severity determines which later phases are mandatory vs. optional.

Severity	Criteria	Required Response
Low	No interaction; link-only, low-value target	Standard analysis + IOC block, no containment
Medium	Email opened, link clicked, no credentials entered	Full analysis + monitor account for anomalous activity
High	Credentials entered, or attachment opened/executed	Full analysis + immediate password reset + session revocation
Critical	Privileged account affected, or confirmed lateral movement / data exfiltration	Full IR activation — escalate to CIRT lead and legal/compliance

4. Phase 1 — Detection & Triage (Target: under 10 minutes)

1. Confirm how the email was surfaced: user report, secure email gateway (SEG) quarantine, or SIEM alert.
2. Identify every recipient/mailbox the message reached.
3. Ask the single most important question: did anyone interact with it — opened, clicked, entered data, opened attachment?
4. Apply the Severity Classification Matrix (Section 3) based on the answer to Step 3.

Tools: Email security gateway console (Proofpoint / Mimecast / Microsoft Defender for Office 365), SIEM (Splunk / Sentinel / QRadar) for recipient search.

5. Phase 2 — Evidence Acquisition & Preservation

5. Export the raw message as .eml or .msg — never work from the rendered preview.
6. Hash the raw file immediately: sha256sum file.eml — record before any further analysis.
7. Store the original, untouched file in the case folder before making any copies to work from.

Tools: Outlook “Save As” (.msg) or admin export tools; command line sha256sum / Get-FileHash.

6. Phase 3 — Header Analysis

8. Extract the full raw header block (From, Reply-To, Return-Path, Received chain, Message-ID, X-Mailer).
9. Check From / Reply-To / Return-Path for mismatches.
10. Read the Received chain bottom-to-top to confirm a plausible, unbroken hop sequence.
11. Note the originating/sending IP for later enrichment.

Tools: Google Admin Toolbox Messageheader (toolbox.googleapps.com/apps/messageheader), MXToolbox Header Analyzer.

7. Phase 4 — Authentication Analysis (SPF / DKIM / DMARC)

Interpret results using the table below — do not treat a pass as a clean bill of health.

Result	What It Confirms	What It Does NOT Confirm
SPF Pass	Sending IP is authorized for that exact domain	That the domain isn't attacker-controlled or a free/abused platform
DKIM Pass	Message wasn't altered in transit	Intent or trustworthiness of the signing domain
DMARC Pass	SPF/DKIM align with the visible From domain	That the visible From domain isn't itself attacker-registered

Critical reminder: free/self-service platforms (help-desk tools, mass-mailers, form builders) can be registered by attackers and will pass all three checks legitimately. Always cross-check the sending domain's relationship to the claimed brand, regardless of authentication results.

8. Phase 5 — Body & Social Engineering Analysis

Work through this checklist and record which techniques are present:

- Brand/identity impersonated
- Greeting type (generic vs. personalized — indicates mass vs. targeted campaign)
- Urgency or time-pressure language
- Loss-aversion or fear-based framing (account suspension, financial loss, legal threat)
- Authority impersonation (executive, IT department, government agency)
- Grammar/spelling anomalies or unusual phrasing
- Sender claim vs. actual sending address/domain mismatch

9. Phase 6 — URL Analysis

12. Extract every URL from the raw HTML body — pull the href attribute, not the displayed link text.
13. Defang every URL before recording it anywhere (hxxp://, [...] in place of .).
14. If the URL is a redirector (bing.com/ck/a, linkedin.com/slink, l.facebook.com, etc.), isolate and decode the embedded destination parameter rather than following the link.
15. Submit the final, decoded destination URL to a sandbox — never visit it directly in a browser.
16. Cross-reference reputation scores across at least two sources before concluding.

Tools: CyberChef (gchq.github.io/CyberChef) for decoding; urlscan.io and VirusTotal for sandboxed URL analysis; never use a personal/production browser to visit unresolved links.

10. Phase 7 — Attachment Analysis

17. Hash the attachment first: sha256sum attachment.ext — check the hash against VirusTotal/MalwareBazaar before any other action.
18. If the hash is already known/flagged, no detonation is required — document the existing verdict.
19. If unknown, detonate only inside an isolated sandbox, never on an analyst workstation.
20. Document observed behavior: dropped files, registry changes, outbound connections (potential C2), persistence mechanisms.

Tools: VirusTotal / MalwareBazaar for hash lookup; Any.Run, Hybrid Analysis, or Joe Sandbox for detonation.

11. Phase 8 — IOC Extraction & Enrichment

Consolidate every artifact into one table, and separate abused-but-legitimate infrastructure from genuinely malicious endpoints:

IOC Type	Enrichment Source	Notes
Sending IP	AbuseIPDB, WHOIS	Check if it belongs to a legitimate shared platform before blocking broadly
Sender domain	VirusTotal, WHOIS (registration date)	Distinguish attacker-registered burner domains from abused legitimate ones
Final landing URL/domain	VirusTotal, urlscan.io	This is usually the correct primary block target
File hash (if attachment present)	VirusTotal, MalwareBazaar	Check before sandboxing — may already be a known sample

Handling clean/low-detection results: archived or already-remediated campaigns will often show clean reputation scores. Do not default to “benign” on a clean scan alone — the verdict should rest on the totality of header, content, and redirect-chain findings (Phases 3–6), with reputation results noted as a point-in-time data point.

12. Phase 9 — MITRE ATT&CK Mapping

Map confirmed behaviors to ATT&CK Enterprise techniques for detection-engineering and reporting consistency:

Tactic	Common Technique(s)	When to Apply
Initial Access	T1566.001/.002 — Spearphishing Attachment / Link	Always — this is the delivery mechanism for nearly every phishing case
Defense Evasion	T1036.005 — Masquerading: Match Legitimate Name	When brand/sender impersonation or abused legitimate infrastructure is present
Execution	T1204.001/.002 — User Execution	When the attack depends on the victim clicking a link or opening a file
Credential Access	T1056 — Input Capture (applied by convention)	When the final destination is assessed as a credential-harvesting page

13. Phase 10 — Containment

Apply based on the severity tier determined in Phase 1 (Section 3):

- Low: Block IOCs at email gateway/firewall/DNS filter; no further action
- Medium: Above + monitor affected accounts for anomalous sign-in activity for 7 days
- High: Above + immediate password reset + revoke active sessions/tokens + purge message from all mailboxes
- Critical: Above + isolate affected endpoints + escalate to IR Lead and Legal/Compliance + activate full incident response process

Tools: Identity provider admin console (Entra ID / Okta) for session revocation; EDR (CrowdStrike / Defender for Endpoint) for endpoint isolation; SEG admin console for mail purge.

14. Phase 11 — Reporting & Notification

21. Complete the standard Phishing Incident Report (see companion template) with all findings from Phases 3–9.
22. Notify affected users and, for High/Critical severity, broader staff if the campaign appears widespread.
23. Report the abused infrastructure (e.g., a help-desk platform account) to that provider's trust & safety/abuse team.
24. For High/Critical incidents, report to your sector ISAC and/or CISA per organizational policy.

15. Phase 12 — Post-Incident Review

- Was detection-to-containment time within target? (Recommend: triage <10 min, containment <1 hour for High/Critical)
- Did this campaign reveal a gap in current detection rules or email security policy?
- Should a new IOC feed, sender pattern, or platform-abuse trend be flagged to email security administrators?
- Update this playbook if a new technique was observed that isn't yet covered.

Appendix A — Tool Reference

Task	Tool
Header analysis	Google Admin Toolbox Messageheader, MXToolbox
URL/redirect decoding	CyberChef
URL sandboxing	urlscan.io, VirusTotal
File/hash reputation	VirusTotal, MalwareBazaar (abuse.ch)
Malware detonation	Any.Run, Hybrid Analysis, Joe Sandbox
IP/domain reputation	AbuseIPDB, AlienVault OTX
Domain registration history	WHOIS (whois.domaintools.com)
Historical page captures	Wayback Machine (web.archive.org)
Session/token revocation	Identity provider admin console (Entra ID, Okta)

Appendix B — Quick Decision Tree

Did the user enter credentials or execute an attachment?

- YES → Severity = High/Critical. Skip to Phase 10 containment immediately, then complete analysis phases in parallel.
- NO, but they clicked a link → Severity = Medium. Complete full analysis, monitor account.
- NO interaction at all → Severity = Low. Complete full analysis at standard pace, block IOCs.